Messagerie souveraine de l'administration

Messagerie instantanée (messages, groupes, fichiers, messages vocaux) pour les agents de l'administration publique burkinabè, **hébergeable sur l'infrastructure de l'État**, dont le serveur **ne peut rien lire**. Projet du sprint technique pré-hackathon, Hackathon 226 (édition 2026).

Concept

Les agents échangent des informations de service sur des messageries dont les serveurs échappent à l'État. Ici, tout est chiffré de bout en bout dans le navigateur, seuls des agents enrôlés entrent, et une révocation coupe l'accès sur tous les appareils. Au-dessus de ce socle, trois fonctions pensées pour la **chaîne de commandement** :

1. **Niveaux de classification** (normal, diffusion restreinte, confidentiel) portés *dans* le message chiffré : transfert interdit, expiration automatique, masquage et filigrane des messages confidentiels.
2. **Instructions de service avec accusé de lecture probant** : l'auteur voit qui a lu et qui reste à relancer, et exporte un rapport de preuve fondé sur l'empreinte SHA-256 du texte.
3. **Messages vocaux** chiffrés, et interface multilingue (mooré **partiel**, voir `docs/traduction-moore.md`).

Architecture

```
Navigateur (client web, chiffrement Rust/WebAssembly)
        │ HTTPS en production
      Caddy ── Client statique + proxy
        ├── Synapse (serveur Matrix, sans fédération) ── PostgreSQL
        ├── Keycloak (identité: mot de passe + TOTP obligatoire, rôles)
        └── Service d'administration (enrôlement, révocation, annuaire)
```

Protocole de chiffrement : **Matrix** (Olm pour les échanges directs, Megolm pour les groupes), par la bibliothèque officielle `matrix-sdk-crypto` (Rust). **Aucune cryptographie n'est écrite par l'équipe.** Un module serveur refuse en plus les contenus en clair qu'il sait reconnaître (types de message, états personnalisés, enveloppe chiffrée mal formée). Il ne peut pas vérifier qu'un texte « chiffré » l'est vraiment : voir les limites.

Technologies et licences

Voir `THIRD-PARTY.md` (versions, licences, liens). En bref : Synapse (AGPL-3.0), Keycloak (Apache-2.0), PostgreSQL (licence PostgreSQL), Caddy (Apache-2.0), `matrix-js-sdk` et `matrix-sdk-crypto-wasm` (Apache-2.0), Fastify et `jose` (MIT). Aucun service tiers n'est nécessaire au fonctionnement. Code de ce dépôt : **AGPL-3.0-or-later** (`LICENSE`).

Niveau d'engagement open source : Créer

Application nouvelle reposant sur une bibliothèque éprouvée (`matrix-js-sdk`), au-dessus d'un serveur Synapse **non modifié** (un module de configuration, `deploy/synapse/modules/no_plaintext.py` , s'y branche). Nous n'avons pas soumis de contribution à un projet amont.

Installation (une commande)

Prérequis : Docker avec Compose v2, environ 4 Go de mémoire libre, un navigateur récent.

```
docker compose up -d --wait        # 2 à 3 minutes la première fois
```

Puis ouvrir http://localhost:8080. Tout est généré automatiquement (secrets, configuration, comptes de démonstration). Remise à zéro complète : `bash scripts/clean-install-check.sh --yes` (détruit données et volumes).

Comptes de démonstration (tous fictifs, mot de passe commun `Demo-Burkina-2026!`) :

Compte	Rôle
`admin.demo`	administrateur
`issa.kabore`	chef de service
`awa.ouedraogo` , `moussa.sawadogo`	agents

Le **second facteur** est obligatoire. Enregistrer le secret `IJ2XE23JNZQUIZLNN5KG65DQGIYDENRQ` dans une application d'authentification, ou obtenir le code courant avec `node scripts/totp-demo.mjs awa.ouedraogo` .

Pour une vraie installation : mettre `DEMO_ACCOUNTS=false` **avant le premier démarrage** (ces identifiants sont publics), servir le client et Keycloak en **HTTPS** (le chiffrement du navigateur l'exige hors `localhost`), et retirer `skip_verification` de `deploy/synapse/homeserver.yaml.tmpl` (réglage réservé à la démonstration en HTTP).

Administration : enrôler et révoquer

```
node scripts/admin.mjs list
node scripts/admin.mjs enroll nouvel.agent "Nom Prénom" "Ministère" "Fonction" agent
node scripts/admin.mjs revoke moussa.sawadogo    # coupe l'accès sur tous ses appareils, tout de suite
```

Un compte révoqué ne se réactive pas : enrôler un nouvel identifiant.

Pièces du dossier

Les PDF des notes sont dans `dossier/` ; `cd scripts/pdf && npm ci && node build-pdf.mjs` les régénère et **compte leurs pages réelles** (limite : 2 pages). À relancer après toute modification des notes.

Tests

```
docker compose -f compose.yaml -f compose.test.yaml up -d --wait
bash scripts/test-security.sh      # 62 tests d'intégration (garanties de sécurité et fonctions), 110 tests unitaires en plus
```

Limites

- Le **nom des salons, les membres et les droits** sont visibles du serveur (non chiffrés par Matrix), ainsi que « qui parle dans quel salon, quand, et la taille ». Détail et mesures dans `docs/note-securite.md`.
- Le flou des messages confidentiels **dissuade**, il ne bloque pas les captures d'écran (impossible sur le web).
- Le rôle chef_de_service n'est pas appliqué : seule l'API d'administration exige un rôle (dmin) ; émettre une instruction de service exige d'être modérateur du salon.
- Pas d'écran de vérification des appareils ; le jeton et les clés restent dans le navigateur, non chiffrés au repos.
- Heures de lecture et d'expiration : horloge de chaque appareil.
- L'**installation** télécharge des images Docker et des paquets (construction du client) : le fonctionnement n'en dépend pas, mais un déploiement isolé doit prévoir un miroir interne.
- La configuration livrée est celle d'une machine locale (localhost, uth.localhost) : un autre nom d'hôte demande de modifier SERVER_NAME, l'adresse publique, les redirections Keycloak et l'émetteur dans deploy/.
- Mooré partiel, dioula absent ; annuaire disponible côté serveur mais pas dans l'interface ; ni mode dégradé, ni archivage légal.

Transparence

Ce prototype a été développé avec l'aide d'un assistant IA, ce que le règlement du sprint autorise ; les commits en portent la mention. L'historique Git commence le 30 octobre 2026.